การออกแบบสถาปัตยกรรมของระบบ

System Architecture Design

รหัสเอกสาร MEP-SAD-001-1.0

ระบบจัดซื้อจัดจ้างขนาดย่อ (Mini e-Procurement) โจทย์สมมติเพื่อแสดงผลงาน

ผู้จัดทำ: บารเมษฐ์ นามมุงคุณ

สารบัญ

1 บทนำและขอบเขต **4**

2 ภาพรวมสถาปัตยกรรม **4**

2.1 บริบทของระบบ 4

2.2 แผนภาพหน่วยประกอบ 5

2.3 รายละเอียดหน่วยประกอบ 5

3 การแบ่งโมดูลของ API **6**

4 มุมมองขณะทำงาน (Runtime View) **7**

5 การติดตั้ง **9**

5.1 แผนภาพการติดตั้ง 9

5.2 สภาพแวดล้อม 9

6 ความมั่นคงปลอดภัย **10**

6.1 ขอบเขตความเชื่อถือ 10

6.2 มาตรการหลัก 10

6.3 การเทียบกับ OWASP Top 10 11

7 คุณลักษณะคุณภาพและมาตรการเชิงสถาปัตยกรรม **11**

8 การตัดสินใจเชิงสถาปัตยกรรม **12**

สารบัญรูปภาพ

รูปที่ 2.1-1 บริบทของระบบ 4

รูปที่ 2.2-1 หน่วยประกอบของระบบ 5

รูปที่ 4-1 ลำดับการทำงานขณะส่งใบขอซื้อ 7

รูปที่ 4-2 ลำดับการทำงานขณะอนุมัติขั้นสุดท้าย 8

รูปที่ 5.1-1 มุมมองการติดตั้งในสภาพแวดล้อมใช้งานจริง 9

รูปที่ 6.1-1 ขอบเขตความเชื่อถือ 10

สารบัญตาราง

ตารางที่ 2.3-1 หน่วยประกอบของระบบ 6

ตารางที่ 3-1 โมดูลของ API service 6

ตารางที่ 5.2-1 สภาพแวดล้อมของระบบ 10

ตารางที่ 6.3-1 ความเสี่ยงตาม OWASP และมาตรการ 11

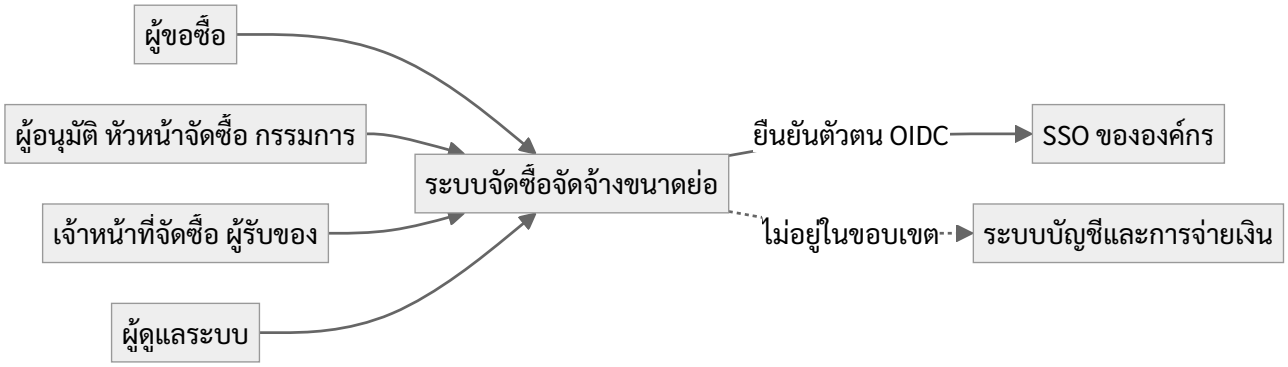
ตารางที่ 7-1 คุณลักษณะคุณภาพและมาตรการ 11

1 บทนำและขอบเขต

เอกสารนี้อธิบายสถาปัตยกรรมของระบบจัดซื้อจัดจ้างขนาดย่อ: บริบท หน่วยประกอบ การแบ่งโมดูลของ API มุมมองขณะทำงาน การติดตั้ง ความมั่นคงปลอดภัย ความสัมพันธ์กับคุณลักษณะคุณภาพ และการตัดสินใจสำคัญ ทุกข้อเสนอเป็นร่างของ AI จากข้อกำหนดในเอกสารอื่น ผู้จัดทำต้องตรวจรับก่อนใช้ เทคโนโลยีที่เลือกสอดคล้องกับ schema ที่ออกแบบไว้ (SQL Server) ไม่ได้ผ่านการทดลองใช้งาน

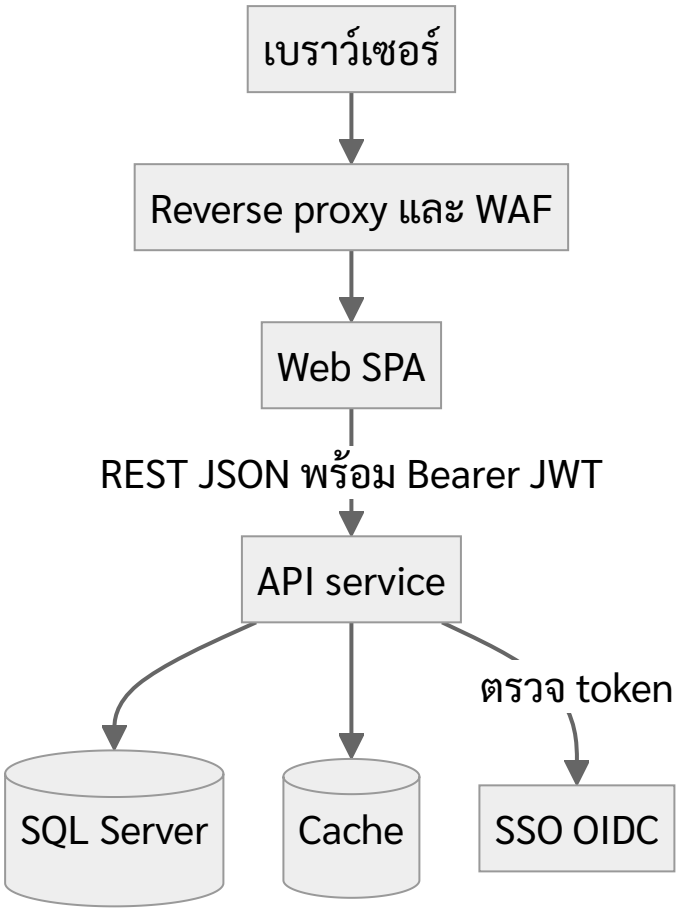
2 ภาพรวมสถาปัตยกรรม

2.1 บริบทของระบบ



รูปที่ 2.1-1 บริบทของระบบ

2.2 แผนภาพหน่วยประกอบ



รูปที่ 2.2-1 หน่วยประกอบของระบบ

2.3 รายละเอียดหน่วยประกอบ

หน่วย	เทคโนโลยี	หน้าที่	เจ้าของ
Reverse proxy และ WAF	TLS, ตัวกรองคำขอ, จำกัดอัตราการเรียก	ปลายทางเดียวที่เปิดสู่ผู้ใช้ ยกเลิก TLS และตัดคำขอผิดปกติก่อนถึง API	ภายใน (ผู้ให้บริการโครงสร้างพื้นฐาน)
Web SPA	React และ TypeScript	แสดง 10 หน้าจอ จัดรูปแบบวันที่ พ.ศ. และเงินบาท สร้าง Idempotency-Key ต่อการกระทำ และจัดการข้อผิดพลาดตามรหัส	ภายใน
API service	ASP.NET Core (.NET 8) แบบ modular monolith	บังคับสิทธิ์ ขอบเขตข้อมูล กฎธุรกิจ และขอบเขตธุรกรรมของทุก operation	ภายใน
ฐานข้อมูล	SQL Server 2022	ที่เก็บข้อมูลหลัก ตาม `sql/schema.sql` รวมขั้นตอนออกเลขเอกสารและตาราง audit แบบเพิ่มอย่างเดียว	ภายใน
แคช	Redis	เก็บผลของคำสั่งที่มี Idempotency-Key 24 ชั่วโมง ไม่ใช่แหล่งข้อมูลหลัก	ภายใน

หน่วย	เทคโนโลยี	หน้าที่	เจ้าของ
SSO	OpenID Connect ขององค์กร	ยืนยันตัวตนและออก JWT ที่มีรหัสผู้ใช้และบทบาท	ภายนอก

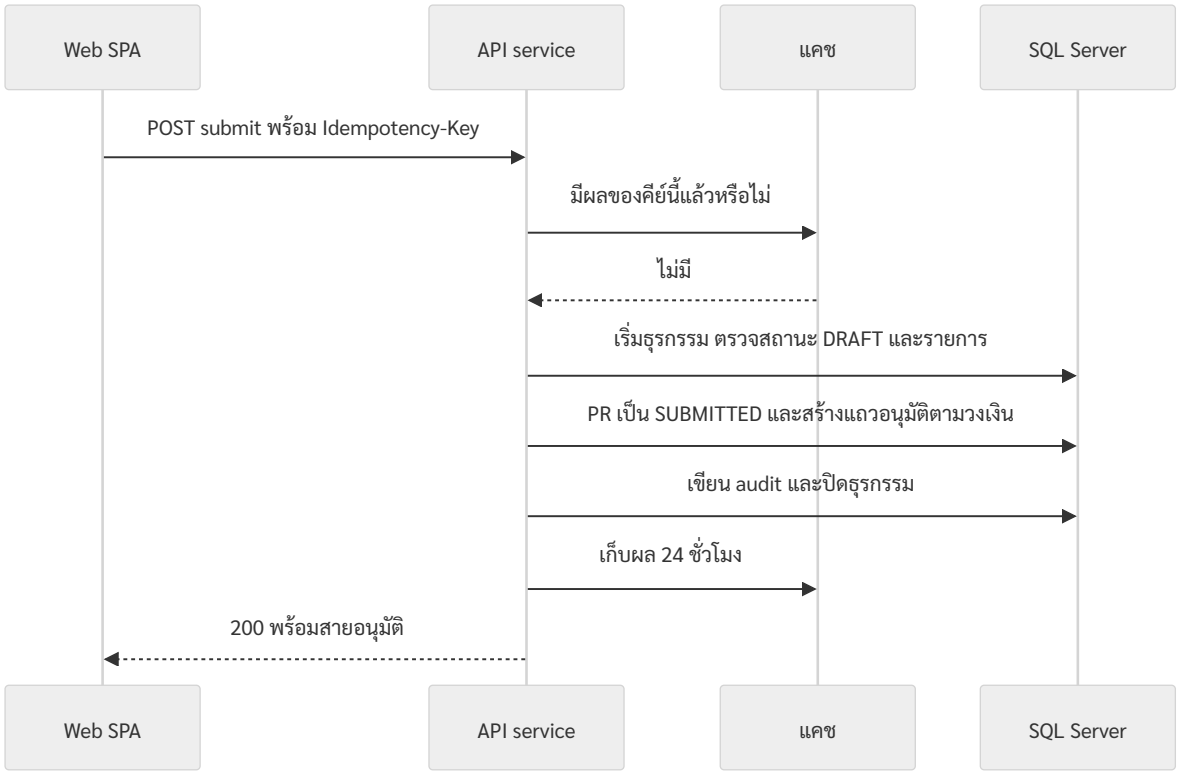
ตารางที่ 2.3-1 หน่วยประกอบของระบบ

3 การแบ่งโมดูลของ API

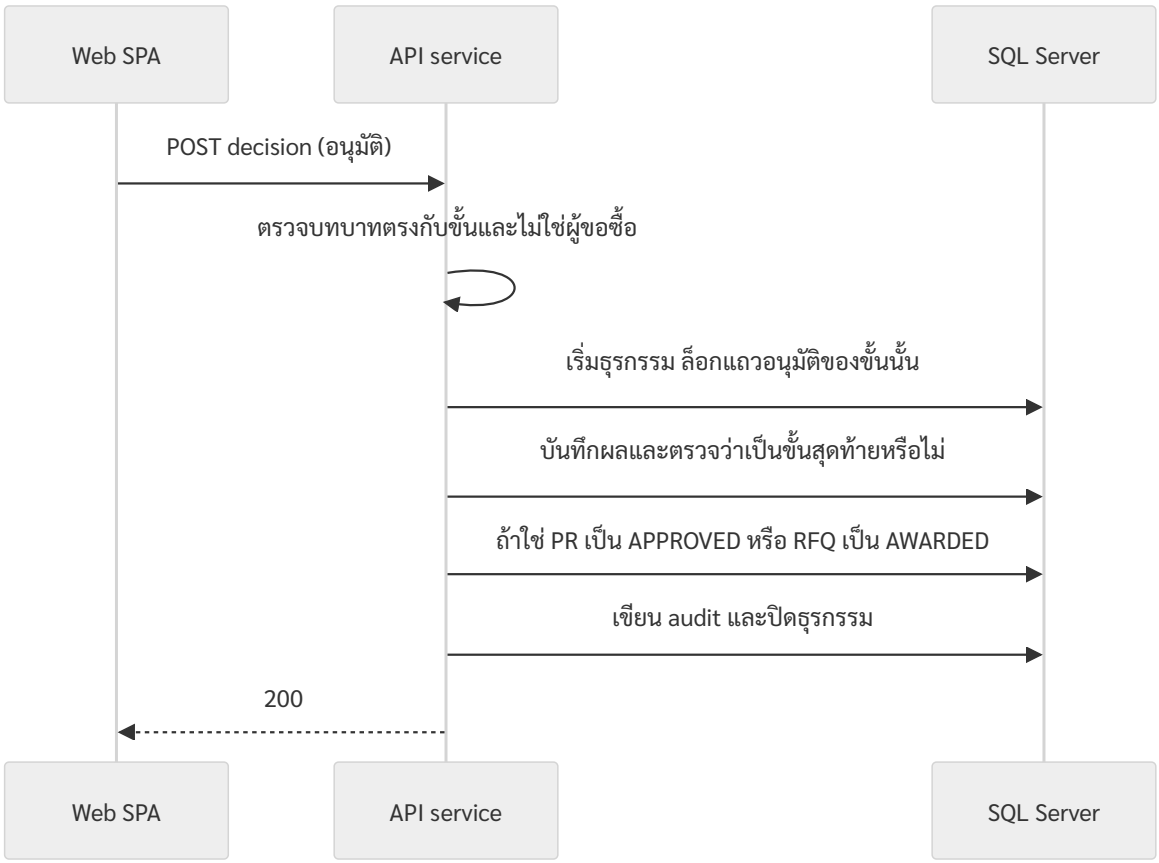
โมดูล	หน้าที่	FR	API operation
โมดูลใบขอซื้อ	สร้าง แก้ ค้นหา และส่ง PR คำนวณวงเงินรวม	FR-01, FR-02, FR-03	listPurchaseRequests, createPurchaseRequest, getPurchaseRequest, updatePurchaseRequest, submitPurchaseRequest
โมดูลอนุมัติ	สร้างสายอนุมัติตามวงเงิน ตรวจการแยกหน้าที่ และเปลี่ยนสถานะเมื่ออนุมัติขั้นสุดท้าย	FR-04	listMyApprovals, decideApproval
โมดูลจัดหา	สร้าง RFQ รับใบเสนอราคา เปรียบเทียบ และเสนอผลเลือก	FR-05, FR-06, FR-07, FR-08	createRfq, recordQuotation, getQuotationComparison, awardRfq
โมดูลสั่งซื้อและรับของ	ออก PO และบันทึกการรับของ คำนวณสถานะ PO และ PR	FR-09, FR-10	createPurchaseOrder, issuePurchaseOrder, recordGoodsReceipt
โมดูลผู้ขาย	ทะเบียนผู้ขายและการระงับ	FR-11	listVendors, createVendor, setVendorStatus
โมดูลรายงาน	รายงานสรุปการจัดซื้อแบบอ่านอย่างเดียว	FR-12	getSpendSummary
โมดูล audit	บันทึกและอ่านเหตุการณ์ ทุกโมดูลเรียกใช้ตัวเขียน	FR-13	listAuditLogs
โมดูลแพลตฟอร์ม	ใช้ร่วมกันทุกโมดูล: ตรวจสิทธิ์ ออกเลขเอกสาร Idempotency-Key รูปแบบข้อผิดพลาด และตรวจการแก้ไขซ้อน	FR-14	

ตารางที่ 3-1 โมดูลของ API service

4 มุมมองขณะทำงาน (Runtime View)



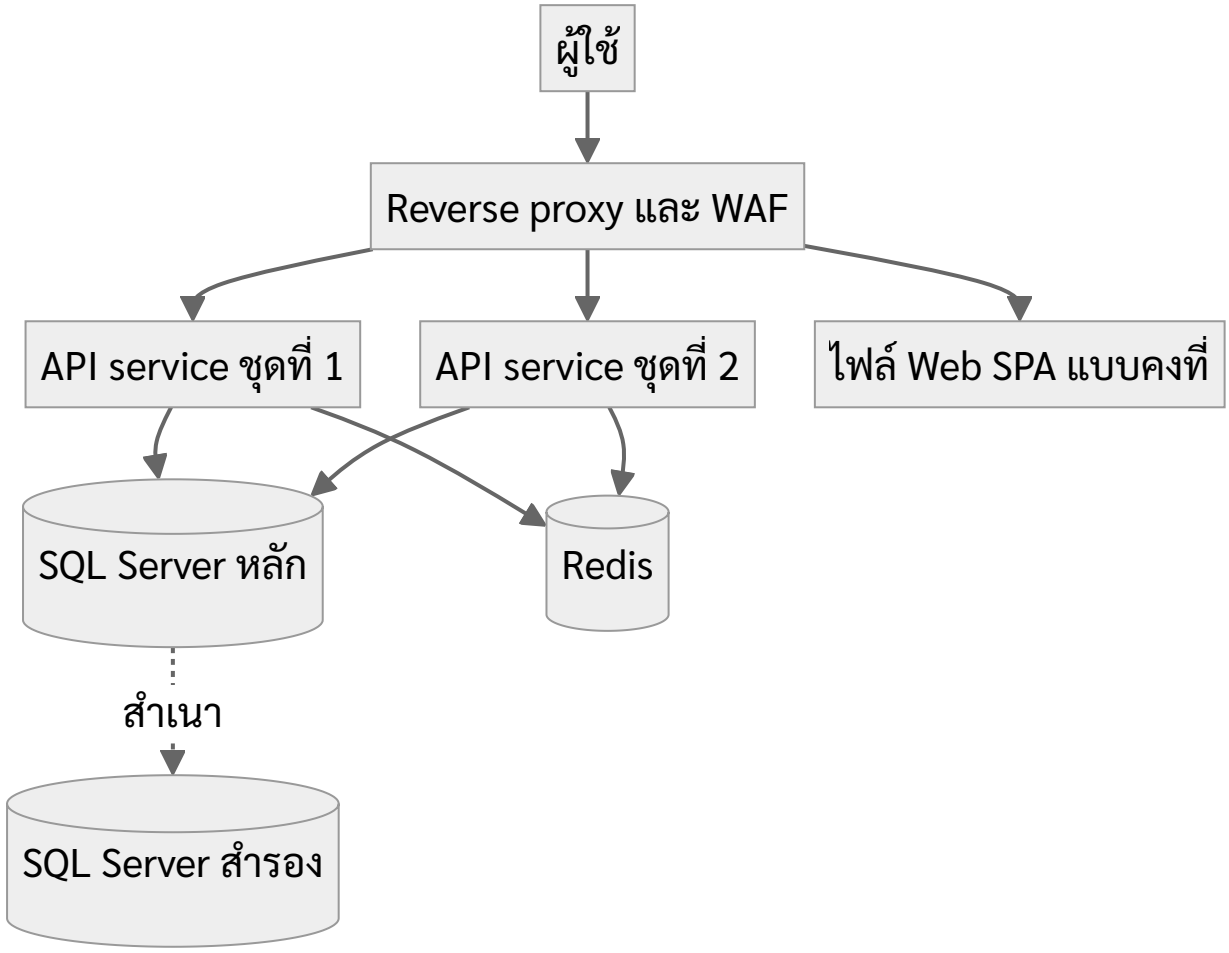
รูปที่ 4-1 ลำดับการทำงานขณะส่งใบขอซื้อ



รูปที่ 4-2 ลำดับการทำงานขณะอนุมัติขั้นสุดท้าย

5 การติดตั้ง

5.1 แผนภาพการติดตั้ง



รูปที่ 5.1-1 มุมมองการติดตั้งในสภาพแวดล้อมใช้งานจริง

5.2 สภาพแวดล้อม

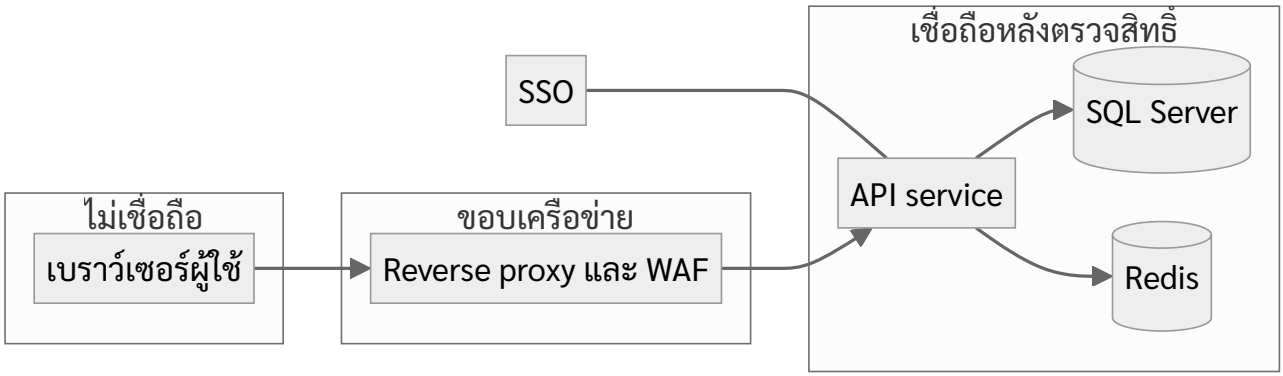
สภาพแวดล้อม	วัตถุประสงค์	ข้อมูล	ผู้ใช้งาน
Dev	พัฒนาและทดสอบหน่วยโดยนักพัฒนา	ข้อมูลสมมติ	ทีมพัฒนา
SIT	ทดสอบระบบรวมตามกรณีทดสอบ	ข้อมูลสมมติที่สร้างจากข้อมูลตัวอย่าง	ทีมพัฒนาและ QA
UAT	ผู้ใช้ตรวจรับตาม Journey	ชุดข้อมูลที่ผู้ใช้เตรียม ไม่มีข้อมูลจริงที่เป็นความลับ	ผู้ใช้และ QA

สภาพแวดล้อม	วัตถุประสงค์	ข้อมูล	ผู้ใช้งาน
Production	ใช้งานจริง	ข้อมูลจริง	ผู้ใช้ทั้งหมด ผู้ดูแลระบบจัดการ

ตารางที่ 5.2-1 สภาพแวดล้อมของระบบ

6 ความมั่นคงปลอดภัย

6.1 ขอบเขตความเชื่อถือ



รูปที่ 6.1-1 ขอบเขตความเชื่อถือ

6.2 มาตรการหลัก

6.2.1 การพิสูจน์ตัวตน

ผู้ใช้ยืนยันตัวตนกับ SSO ด้วย OpenID Connect และส่ง JWT มากับทุกคำขอ API ตรวจลายเซ็น ผู้ออกโทเค็น และวันหมดอายุทุกครั้ง โทเค็นที่หมดอายุหรือไม่ถูกต้องตอบ `ERR-AUTH-001` รหัสผู้ใช้และบทบาทอ่านจาก claim ไม่รับจากเนื้อหาคำขอ

6.2.2 การให้สิทธิ์

ตรวจสองชั้น: บทบาทต้องอยู่ใน `x-roles` ของ operation แล้วตรวจขอบเขตข้อมูลตามหน่วยงานและเจ้าของเอกสารใน service ไม่ผ่านตอบ `ERR-AUTH-002` กฎแยกหน้าที่ (ห้ามอนุมัติของตนเอง) ตรวจที่โมดูลอนุมัติและตอบ `ERR-SOD-001` การซ่อนปุ่มที่หน้าจอเป็นเพียงความสะดวกของผู้ใช้ ไม่ใช่มาตรการความปลอดภัย

6.2.3 audit trail

ทุกการเปลี่ยนสถานะและการตัดสินใจเขียนลง `audit_log` ในธุรกรรมเดียวกับการเปลี่ยนแปลง ตารางนี้เพิ่มอย่างเดียว บัญชีที่แอปใช้ไม่มีสิทธิ์ `UPDATE` หรือ `DELETE` ตรวจแล้วด้วยชุดทดสอบฐานข้อมูล (error 229)

6.3 การเทียบกับ OWASP Top 10

ความเสี่ยง	มาตรการ	กรณีทดสอบที่รองรับ
A01 การควบคุมการเข้าถึงที่บกพร่อง	บทบาทและขอบเขตข้อมูลตรวจที่ API, แยกหน้าที่ในโมดูลอนุมัติ	TC-05, TC-12, TC-16, TC-45, TC-51
A03 การโจมตีแบบ injection	คำสั่งฐานข้อมูลใช้พารามิเตอร์ ไม่ต่อสตริง และตรวจชนิดและช่วงค่าของข้อมูลเข้า	TC-02, TC-03, TC-13, TC-41
A04 การออกแบบที่ไม่ปลอดภัย	เครื่องสถานะของเอกสารและ Idempotency-Key กันการทำซ้ำและการข้ามขั้น	TC-10, TC-11, TC-35
A07 การพิสูจน์ตัวตนบกพร่อง	ใช้ SSO ไม่เก็บรหัสผ่าน ตรวจ token ทุกคำขอ	TC-49
A08 ความสมบูรณ์ของข้อมูลและซอฟต์แวร์	audit แก้ไม่ได้ระดับฐานข้อมูล	TC-47
A09 การบันทึกและเฝ้าระวังบกพร่อง	ทุกการเปลี่ยนสถานะมี audit ในธุรกรรมเดียวกัน	TC-46

ตารางที่ 6.3-1 ความเสี่ยงตาม OWASP และมาตรการ

7 คุณลักษณะคุณภาพและมาตรการเชิงสถาปัตยกรรม

NFR	ข้อกำหนด	มาตรการ	ตรวจด้วย
NFR-01	หน้ารายการ PR ตอบเร็วเมื่อมี PR 100,000 รายการ	keyset pagination บนดัชนีครอบคลุม `ix_pr_status_created` ไม่ใช้ offset	
NFR-02	audit trail แก้ไม่ได้	ตาราง `audit_log` เพิ่มอย่างเดียว และ `DENY UPDATE, DELETE` ให้บัญชีแอป ตรวจที่ระดับฐานข้อมูล	TC-47
NFR-03	ทุก endpoint ตรวจสิทธิ์ตามบทบาทและขอบเขตข้อมูล	JWT จาก SSO, ตรวจ `x-roles` ต่อ operation, กรองข้อมูลตามหน่วยงานใน service, แยกหน้าที่ในโมดูลอนุมัติ	TC-05, TC-12, TC-16, TC-45, TC-51
NFR-04	เลขเอกสารไม่ซ้ำแม้ออกพร้อมกัน	ขั้นตอน `usp_next_doc_no` ล็อกแถวเดียวต่อ (ชนิด, ปี) ไม่ใช้ `MAX()+1`	TC-48
NFR-05	ส่งคำสั่งซ้ำไม่ทำงานซ้ำ	แคชเก็บผลตาม `Idempotency-Key` 24 ชั่วโมง และกฎสถานะของเอกสารเป็นด่านที่สอง	TC-10, TC-11, TC-35
NFR-06	แสดงผลภาษาไทยและวันที่ พ.ศ.	จัดเก็บเวลา UTC ใน `DATETIME2` และแปลงเป็น พ.ศ. ที่ Web SPA ข้อความผิดพลาดเป็นภาษาไทยจาก API	

ตารางที่ 7-1 คุณลักษณะคุณภาพและมาตรการ

8 การตัดสินใจเชิงสถาปัตยกรรม

8.1 ADR-01 เทคโนโลยีหลัก (proposed)

บริบท: ต้องเลือกภาษาและฐานข้อมูลให้เข้ากับ schema T-SQL ที่ออกแบบไว้ (ROWVERSION, ขั้นตอนออกเลข, ดัชนีแบบมีเงื่อนไข)

การตัดสินใจ: ใช้ ASP.NET Core (.NET 8) ฝั่ง API, React และ TypeScript ฝั่งหน้าจอ และ SQL Server 2022

ผลที่ตามมา: ใช้ฟีเจอร์ของ SQL Server ได้เต็ม แต่ผูกกับผู้ขายฐานข้อมูลรายเดียว ทางเลือกอื่นที่ไม่ได้เลือกคือ Node.js หรือ Java กับ PostgreSQL ซึ่งต้องออกแบบ schema ใหม่

8.2 ADR-02 โครงสร้าง API (proposed)

บริบท: ขนาดโจทย์เล็ก ธุรกรรมหลายตารางต้อง commit พร้อมกัน (เช่น อนุมัติขั้นสุดท้ายเปลี่ยนทั้ง approval, PR และ audit)

การตัดสินใจ: ทำ API เป็น modular monolith ที่แยกโมดูลตามหน้าที่แต่ใช้ฐานข้อมูลเดียวและธุรกรรมเดียว

ผลที่ตามมา: ธุรกรรมง่ายและทดสอบง่าย ไม่ต้องจัดการข้อมูลสอดคล้องข้ามบริการ แยกเป็น microservices ภายหลังได้ยากขึ้นถ้าโมดูลอ้างตารางของกันโดยตรง จึงให้โมดูลคุยกันผ่านอินเทอร์เฟซ

8.3 ADR-03 endpoint อนุมัติกลาง (accepted)

บริบท: การอนุมัติ PR และผลเลือกผู้ชนะมีกฎร่วมกัน (สายอนุมัติ, แยกหน้าที่, บันทึกผล)

การตัดสินใจ: ใช้ `/approvals/{id}/decision` เดียว แยกชนิดงานด้วย `docType` แทน endpoint แยกต่อเอกสาร

ผลที่ตามมา: กฎอยู่ที่เดียว เพิ่มชนิดงานใหม่ไม่ต้องเพิ่ม endpoint แต่ `approval` ไม่มี foreign key ไปเอกสารต้นทาง ต้องบังคับด้วยตรรกะและ unique constraint

8.4 ADR-04 ที่เก็บ Idempotency-Key (proposed)

บริบท: ต้องเก็บผลของคำสั่ง 24 ชั่วโมง แต่ไม่ต้องการเพิ่มตารางในฐานข้อมูลหลัก

การตัดสินใจ: เก็บใน Redis พร้อม TTL ไม่เพิ่มตารางใน SQL Server

ผลที่ตามมา: เร็วและหมดอายุเอง แต่ถ้าแคชหาย การส่งซ้ำอาจทำงานซ้ำ จึงต้องมีกฎสถานะของเอกสารเป็นด่านที่สอง (`ERR-STATE-001`) และต้องทดสอบกรณีนี้

8.5 ADR-05 การยืนยันตัวตน (proposed)

บริบท: องค์กรมี SSO กลางอยู่แล้ว ระบบไม่ควรเก็บรหัสผ่าน

การตัดสินใจ: ใช้ OpenID Connect กับ SSO ขององค์กร รับ JWT ที่มีรหัสผู้ใช้และบทบาท และให้ API ตรวจลายเซ็นและวันหมดอายุทุกคำขอ

ผลที่ตามมา: ไม่ต้องจัดการรหัสผ่านและการลืมรหัส แต่ผูกกับความพร้อมของ SSO และต้องตกลงรูปแบบ claim ของบทบาทกับผู้ดูแล SSO ก่อนพัฒนา

8.6 ADR-06 API แบบไม่เก็บสถานะ (proposed)

บริบท: ต้องรันหลายชุดหลัง proxy ตามมุมมองการติดตั้ง

การตัดสินใจ: API ไม่เก็บ session ในหน่วยความจำ สถานะทั้งหมดอยู่ในฐานข้อมูลหรือแคช

ผลที่ตามมา: เพิ่มจำนวนชุดได้โดยไม่มีผลต่อผู้ใช้ แต่ทุกคำขอต้องตรวจ token ใหม่